CÔNG TY CỔ PHẦN XOR CLOUD
KHỐI HẠ TẦNG & VẬN HÀNH

HỒ SƠ

HỒ SƠ ĐỀ XUẤT CẤP ĐỘ 4
HỆ THỐNG XOR SECURE CLOUD

XOR SECURE CLOUD

Tài liệu thuyết minh theo Điều 21 và Điều 22 Nghị định 331 năm 2026

Nền tảng XOR STACK CLOUD dựa trên OpenStack

Đơn vị vận hành: Khối Hạ tầng & Vận hành

DC: Trung tâm Hạ tầng IDC Cầu Giấy
DR: Trung tâm Hạ tầng IDC Nam Thăng Long

Bản dự thảo 2.3 chưa ký ban hành

Hà Nội, tháng 10 năm 2026

Thông tin quản lý hồ sơ	Nội dung
Chủ quản	Công ty Cổ phần XOR CLOUD
Đơn vị vận hành	Khối Hạ tầng & Vận hành
Địa chỉ trụ sở	Tầng 7, Tòa nhà Việt Á, số 09 phố Duy Tân, phường Cầu Giấy, TP Hà Nội
Người ký dự kiến của chủ quản	Lê Anh Vũ — Tổng Giám đốc
Mã hồ sơ	XOR-CD4-HS-01 — bản dự thảo 2.3
Tình trạng	Lập lần đầu; chưa có quyết định phê duyệt cấp độ hoặc chứng nhận.
Phạm vi	Toàn bộ XOR STACK CLOUD và dịch vụ quản trị chung tại DC Cầu Giấy, DR Nam Thăng Long.

Hồ sơ trình bày phương án đề xuất cấp độ 4 và kế hoạch bảo đảm an ninh mạng. Các cấu hình, dung lượng, chỉ tiêu và kết quả chưa được xác minh đều phải được bổ sung trước khi trình ký. Nội dung có cụm từ “phương án” là thiết kế dự kiến; không phải xác nhận biện pháp đã triển khai.

PHẦN I TỔNG QUAN VỀ HỆ THỐNG THÔNG TIN

1 Căn cứ lập hồ sơ

Căn cứ Luật An ninh mạng số 116/2025/QH15; Nghị định số 331/2026/NĐ-CP ngày 19 tháng 8 năm 2026 của Chính phủ về bảo vệ an ninh mạng đối với hệ thống thông tin; căn cứ chức năng, nhiệm vụ và thẩm quyền của chủ quản [CẦN ĐÍNH KÈM VĂN BẢN]; căn cứ hiện trạng và nhu cầu bảo vệ hệ thống XOR SECURE CLOUD, đơn vị vận hành lập hồ sơ đề xuất cấp độ 4 để xin ý kiến chuyên môn, thẩm định và trình phê duyệt theo quy định.

TCVN 14423:2026, Điều 6 và Phụ lục A.4 được sử dụng làm cơ sở kỹ thuật đối chiếu phương án. Dự thảo tiêu chuẩn Cloud được theo dõi riêng để cải thiện thiết kế, không đưa vào căn cứ pháp lý bắt buộc của hồ sơ này. [S1, Điều 21–22; S2]

2 Thông tin chủ quản và đơn vị vận hành

Trường thông tin	Chủ quản	Đơn vị vận hành
Tên đầy đủ	Công ty Cổ phần XOR CLOUD	Khối Hạ tầng & Vận hành
Mã số doanh nghiệp/định danh	[CẦN ĐIỀN theo đăng ký doanh nghiệp]	Đơn vị nội bộ của chủ quản
Chức năng, nhiệm vụ và quyền hạn	[CẦN ĐIỀN; dẫn văn bản]	[CẦN ĐIỀN; dẫn quyết định giao vận hành]
Đại diện và đầu mối phụ trách	Lê Anh Vũ — Tổng Giám đốc	Trần Văn Dũng — Giám đốc Khối Hạ tầng & Vận hành
Địa chỉ và liên hệ	Tầng 7, Tòa nhà Việt Á, số 09 phố Duy Tân, phường Cầu Giấy, TP Hà Nội; [điện thoại/email]	Tầng 7, Tòa nhà Việt Á, số 09 phố Duy Tân, phường Cầu Giấy, TP Hà Nội; [CẦN ĐIỀN điện thoại/email]
Đơn vị chuyên trách ANM	Trung tâm Vận hành; [CẦN ĐÍNH KÈM quyết định giao nhiệm vụ]	Trần Văn Dũng; [CẦN XÁC NHẬN phân công và cơ chế độc lập]

Đầu mối lập hồ sơ: Chử Quang Thắng — Giám đốc Vận hành. Tư cách chủ quản, nhiệm vụ vận hành/chuyên trách và thẩm quyền ký phải kèm văn bản phân công hoặc ủy quyền phù hợp; xác nhận cơ chế kiểm tra độc lập trước khi trình.

3 CHỨC NĂNG PHẠM VI VÀ QUY MÔ

XOR SECURE CLOUD là hệ thống cung cấp và quản lý tài nguyên điện toán đám mây trên nền tảng XOR STACK CLOUD do đội ngũ XOR CLOUD phát triển lại và đóng gói từ OpenStack. Phạm vi hồ sơ gồm hạ tầng, phần mềm nền tảng và các dịch vụ quản trị chung tại Trung tâm Hạ tầng IDC Cầu Giấy (DC) và Trung tâm Hạ tầng IDC Nam Thăng Long (DR).

Phạm vi kỹ thuật dự kiến bao gồm máy chủ, ảo hóa, mạng, lưu trữ, portal/API, control plane, định danh và đặc quyền, quản lý khóa/chứng thư, DNS/thời gian, giám sát/nhật ký, sao lưu/DR, chuỗi phát hành và máy trạm quản trị. Danh mục dịch vụ được cung cấp thực tế và các thành phần thuê ngoài được chốt tại Phụ lục PL01. [S1, Điều 22.3]

Nội dung	Số liệu phải điền và tài liệu chứng minh
Đối tượng phục vụ	[CẦN ĐIỀN nhóm khách hàng, địa bàn, số tổ chức/tenant/người dùng và phạm vi toàn quốc nếu có].
Quy mô hai IDC	[CẦN ĐIỀN số rack, host/controller/compute/storage/network; dung lượng; tải và năng lực dự phòng từng site].
Dịch vụ	[CẦN CHỐT IaaS/VM, network, block/object/file, K8s, DBaaS, GPU và dịch vụ quản lý thực tế].
Thông tin xử lý	[CẦN ĐIỀN loại dữ liệu, độ nhạy cảm, dữ liệu cá nhân/quan trọng và dữ liệu thuộc quy định chuyên ngành nếu có].
Kết nối ngoài	[CẦN ĐIỀN ISP, hệ thống khách hàng, đối tác, dịch vụ dùng chung, cơ quan quản lý và kênh liên site].
SLA và thời gian hoạt động	[CẦN ĐIỀN nghĩa vụ 24/7, thời gian bảo trì, RPO/RTO và điều khoản hợp đồng/BIA].

4 Ranh giới trách nhiệm

XOR chịu trách nhiệm đối với hạ tầng, nền tảng và dịch vụ đã cam kết quản lý. Chủ quản của từng hệ thống khách hàng chịu trách nhiệm mục đích sử dụng, phân loại dữ liệu, tài khoản và các cấu hình/ứng dụng thuộc phần mình quản lý. Ranh giới phải được cụ thể hóa theo hợp đồng, dịch vụ và ma trận trách nhiệm; việc phê duyệt cấp độ nền tảng không thay thế hồ sơ cấp độ của từng hệ thống khách hàng.

PHẦN II THIẾT KẾ VÀ HIỆN TRẠNG HỆ THỐNG

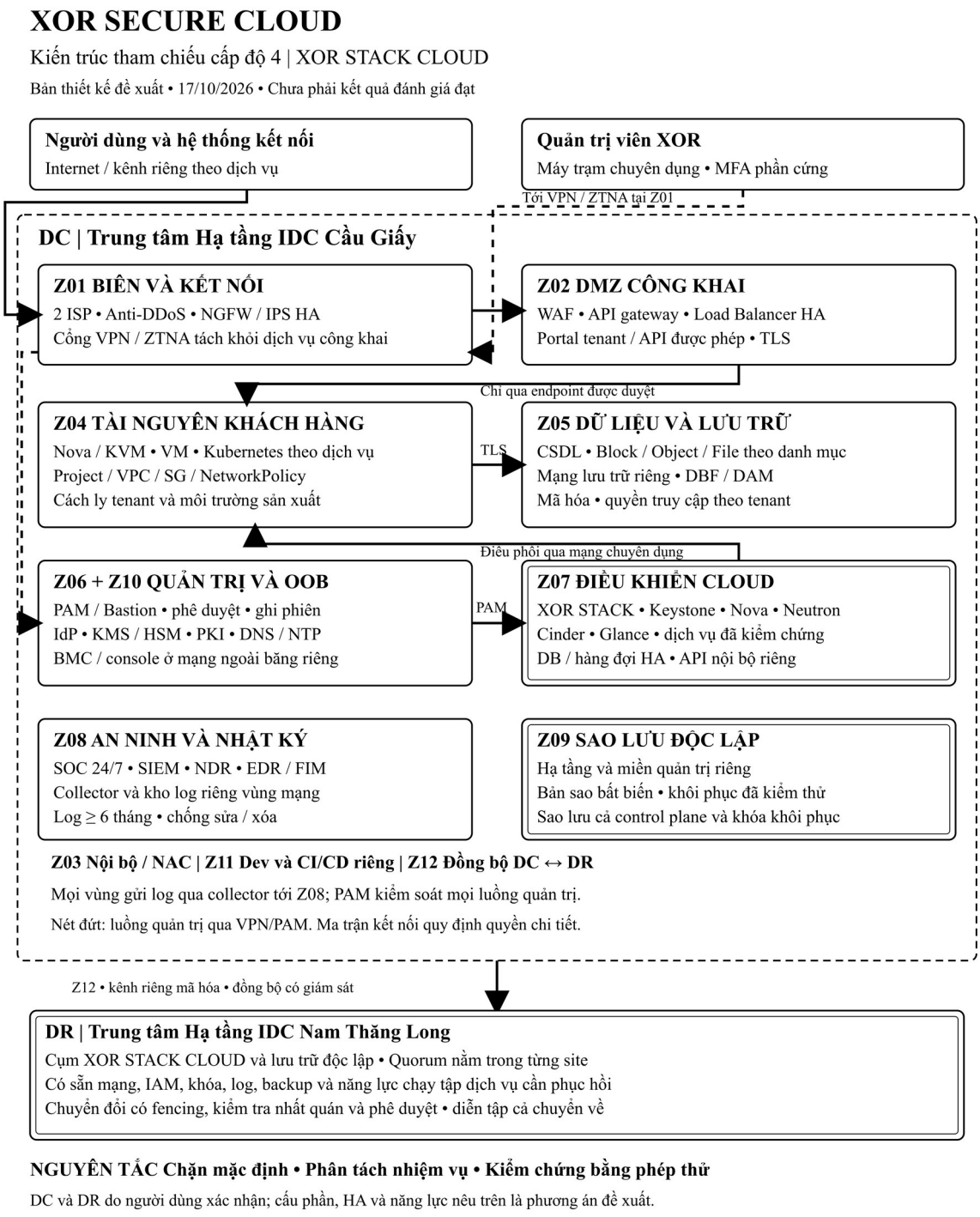
Đối với hệ thống đang vận hành, tài liệu kèm theo phải là thiết kế thi công đã được cấp có thẩm quyền phê duyệt hoặc tài liệu có giá trị tương đương. Bản kiến trúc tham chiếu trong hồ sơ này được dùng làm phương án hoàn thiện; đơn vị vận hành phải đối chiếu và xác nhận bằng hồ sơ as-built trước khi trình. [S1, Điều 21.2 b]

1 Danh mục thiết kế và phụ lục hiện trạng

Mã	Tài liệu phải kèm theo	Trường bắt buộc
PL01	Dịch vụ và ứng dụng	Tên, chức năng, đối tượng, máy chủ/vị trí, OS, phiên bản, chủ sở hữu và phạm vi XOR quản lý.
PL02	Thiết bị và cấu hình vật lý	ID, loại, model/serial, rack, site, vai trò, kết nối, nguồn, phiên bản và EOL.
PL03	Phân vùng mạng và IP	VLAN/VRF/VXLAN, CIDR, IP private/public, route, endpoint, owner và mục đích.
PL04	Luồng dữ liệu và kết nối	Nguồn/đích/cổng/giao thức, phân loại dữ liệu, xác thực, mã hóa, log, tần suất và phê duyệt.
PL05	Danh mục dữ liệu và quyền	Chủ dữ liệu, mức nhạy cảm, kho, quyền, thời hạn lưu, hủy, sao lưu và khóa.
PL06	HA backup và DR	Phụ thuộc, quorum, miền lỗi, capacity, replica, RPO/RTO, runbook, restore và diễn tập.
PL07	Cấu hình và phiên bản	Baseline, inventory, SBOM, khác biệt XOR/upstream, CI/CD, phê duyệt và rollback.

Trạng thái hiện tại: [CẦN ĐÍNH KÈM bộ thiết kế thực tế, số/ngày phê duyệt và danh mục phiên bản]. Dải IP, số lượng node và sản phẩm cụ thể trong tài liệu cũ không được dùng làm số liệu hiện trạng nếu chưa xác minh.

2 SƠ ĐỒ KIẾN TRÚC THAM CHIẾU



Hình 1. Phương án mục tiêu cho toàn nền tảng. Bổ sung sơ đồ hiện trạng lô-gic và vật lý đã xác nhận tại PL02–PL04. Các thành phần bảo mật thể hiện trên hình chưa được xác nhận đã triển khai.

3 PHƯƠNG ÁN PHÂN VÙNG VÀ LUỒNG KẾT NỐI

Vùng	Chức năng và giới hạn
Z01 Biên	Kết nối ISP, chống DDoS, NGFW/IPS và cổng VPN/ZTNA; tách listener quản trị.
Z02 DMZ	WAF, API gateway/LB và endpoint công khai được duyệt; chặn truy cập trực tiếp origin.
Z03 Nội bộ	Người dùng nội bộ và thiết bị; kiểm soát kết nối bằng NAC hoặc tương đương.
Z04 Tài nguyên tenant	VM/container, project/SG/policy; tách tenant và môi trường.
Z05 Dữ liệu	DB, block/object/file; tách mạng lưu trữ, quyền và khóa theo phạm vi.
Z06 Quản trị	PAM, IAM, PKI/KMS và dịch vụ quản trị; phân khu chức năng; không truy cập Internet trực tiếp.
Z07 Điều khiển	Controller/API nội bộ, DB trạng thái và hàng đợi; mTLS/ACL theo phiên bản.
Z08 An ninh	SOC, collector, SIEM và kho log khác vùng phát sinh; quyền quản trị độc lập.
Z09 Sao lưu	Kho và miền quản trị độc lập; kiểm soát xóa, phiên bản và mã hóa.
Z10 Ngoài băng	BMC/console và quản trị thiết bị; chỉ qua đích quản trị được phép.
Z11 Phát triển	Git/CI/build/registry/dev/test, tách production và bí mật.
Z12 Liên site	Đồng bộ DC–DR trên kết nối riêng được bảo vệ; chỉ cho phép peer/luồng đã duyệt.

Mọi vùng áp dụng chặn mặc định; quyền kết nối được xác định theo nhu cầu dịch vụ và có người sở hữu. Quyền quản trị đi qua cổng kiểm soát và PAM; không cấp tuyến mạng rộng cho người truy cập từ xa. Phương án kiểm soát ranh giới lõi với vùng ít tin cậy phải thuyết minh Datadiode/USG/BSG hoặc biện pháp tương đương phù hợp từng luồng. [S2, 6.12.2.1–6.12.2.6]

4 PHƯƠNG ÁN NỀN TẢNG DỮ LIỆU VÀ PHỤC HỒI

4 1 Nền tảng XOR STACK CLOUD

Mỗi IDC được thiết kế thành cụm độc lập, có quorum nội bộ cho các thành phần yêu cầu đồng thuận. Việc bố trí số controller, DB, queue, compute và storage căn cứ vào bản dựng được hỗ trợ và phép đo tải. Không mặc định kéo dài một cụm đồng thuận hoặc miền lỗi duy nhất qua DC và DR. Hệ thống Neutron/SDN, hypervisor và storage được kiểm tra cách ly tenant, metadata, console, snapshot và tái cấp phát tài nguyên.

4 2 Bảo vệ dữ liệu và khóa

Dữ liệu được phân loại theo chủ sở hữu, độ nhạy cảm và mục đích xử lý. Quyền đọc, ghi, xuất, sao lưu và hủy được kiểm soát. Phương án mã hóa dữ liệu quan trọng khi truyền/lưu, bảo vệ khóa, toàn vẹn, chữ ký số, chống thất thoát và nhật ký truy cập được thuyết minh theo từng dòng 6.4 tại tài liệu 02. Đối với cơ chế kiểm soát rủi ro tương đương phải có phân tích và bằng chứng kiểm chứng, không chỉ ghi tên giải pháp.

4 3 Sao lưu và DR

Bản sao dữ liệu, cấu hình và thông tin phục hồi phải được lưu trên hạ tầng độc lập với môi trường vận hành; có phiên bản, mã hóa phù hợp, quản lý quyền và phép thử restore. Danh mục sao lưu bao gồm control plane, dữ liệu dịch vụ thuộc trách nhiệm XOR, cấu hình mạng, image và khóa/chứng thư cần khôi phục. RPO, RTO, dung lượng DR và lịch đồng bộ được chốt theo BIA tại Phần III.

Kịch bản mất DC phải xác nhận nguồn dữ liệu hợp lệ, cô lập nguồn ghi cũ trước kích hoạt DR, phục hồi cả IAM/DNS/KMS và dịch vụ phụ thuộc, đối soát nghiệp vụ và thực hiện chuyển về có kiểm soát. Hai IDC trong cùng khu vực phải được đánh giá rủi ro đồng thời về điện, tuyến cáp, ISP và thiên tai; có biện pháp đối với miền lỗi chung.

4 4 Độc lập dịch vụ phục hồi

Tài liệu khôi phục và bí mật khẩn cấp được lưu ở nơi truy cập được khi nền tảng dừng. Đơn vị vận hành lập đồ thị phụ thuộc và kiểm thử khởi động nguội để phát hiện vòng phụ thuộc. Các nội dung kỹ thuật nêu trên là phương án đề xuất, cần đối chiếu bằng chứng triển khai và biên bản T07–T10.

PHẦN III THUYẾT MINH ĐỀ XUẤT CẤP ĐỘ VÀ RỦI RO

1 Loại hệ thống và tiêu chí đề xuất

XOR SECURE CLOUD được đề xuất xem xét theo loại hệ thống cơ sở hạ tầng thông tin cung cấp tài nguyên điện toán đám mây. Việc phân loại và đề xuất cấp độ phải dựa trên chức năng, phạm vi phục vụ, loại thông tin và hậu quả rủi ro thực tế; tên sản phẩm hoặc mục tiêu kinh doanh không đủ để xác định cấp độ. [S1, Điều 14 và 22]

Tiêu chí Điều 14	Nội dung cần chứng minh đối với XOR	Tình trạng
Khoản 1	Thông tin bí mật nhà nước/quốc phòng/an ninh và hậu quả nghiêm trọng nếu thực tế có phục vụ.	Chưa có bằng chứng; không tự khai có.
Khoản 2	Hạ tầng phục vụ cơ quan/tổ chức phạm vi toàn quốc, yêu cầu 24/7 và không chấp nhận ngừng không có kế hoạch. Cần phạm vi khách hàng, nghĩa vụ dịch vụ và BIA.	Tiêu chí cần xem xét; chưa được xác nhận.
Khoản 3	Hệ thống điều khiển công nghiệp phục vụ công trình thuộc trường hợp được quy định.	Chưa có thông tin áp dụng.
Khoản 4	Quyết định của Thủ tướng hoặc kết quả đánh giá theo Khung quản lý rủi ro an ninh mạng trong trường hợp tương ứng.	Chỉ viện dẫn khi có căn cứ hợp lệ.

Tiêu chí được chọn để trình: [CẦN CHỐT KHOẢN ĐIỀU 14]. Bằng chứng: [CẦN LIỆT KÊ mã tài liệu, hợp đồng/phạm vi phục vụ, BIA và kết quả đánh giá]. Đề xuất cấp độ 4 hiện là mục tiêu lập hồ sơ; chủ quản phải xác nhận căn cứ trước khi gửi xin ý kiến/thẩm định.

2 Hệ thống liên quan

[CẦN LẬP danh mục hệ thống kết nối, phụ thuộc hoặc bị ảnh hưởng khi XOR dừng; tên chủ quản, cấp độ đã được phê duyệt nếu có, dịch vụ trao đổi, loại dữ liệu và mức tác động]. Đối chiếu PL04 và BIA để không bỏ sót các phụ thuộc IAM, DNS, khóa, ISP, IDC và nhà cung cấp. [S1, Điều 22.5 a]

3 BÁO CÁO ĐÁNH GIÁ RỦI RO CHI TIẾT

Phương pháp nội bộ đề xuất gồm: xác định tài sản và dịch vụ, nhận diện mối đe dọa/điểm yếu, xác định khả năng và tác động, đánh giá kiểm soát, quyết định xử lý, đánh giá tồn dư và phê duyệt. Thang 5×5 trong workbook là công cụ nội bộ cần được chủ quản duyệt; không tự thay thế Khung quản lý rủi ro an ninh mạng hoặc tiêu chí pháp lý cấp độ. [S1, Điều 22.5; S2, 6.1]

Rủi ro cần đánh giá	Tác động phải làm rõ	Kiểm soát dự kiến
RR01 Tài khoản cloud admin bị chiếm hoặc lạm dụng	Lộ/sửa dữ liệu nhiều tenant; ảnh hưởng dịch vụ diện rộng	PAM, MFA, tách quyền, log độc lập
RR02 Vượt ranh giới tenant qua API hoặc SDN	Lộ dữ liệu, thay đổi trái phép tài nguyên khách hàng	RBAC, SG, kiểm tra sở hữu và cách ly
RR03 Ransomware phá cả bản chính và bản sao	Không khôi phục được dịch vụ và dữ liệu	Kho độc lập, bất biến, tách quyền và restore
RR04 Mất toàn bộ IDC Cầu Giấy	Gián đoạn đồng thời nhiều dịch vụ khách hàng	DR độc lập, replica, fencing, capacity
RR05 Mất kênh liên site hoặc hai site ghi đồng thời	Dữ liệu không nhất quán hoặc mất giao dịch	Theo dõi lag, quorum riêng, fencing và quy trình DR
RR06 Mất khóa hoặc vòng phụ thuộc phục hồi	Có bản sao nhưng không giải mã/dựng được hệ thống	Backup khóa, bí mật khẩn cấp và cold start
RR07 Lỗ hổng hoặc mã độc trong bản đóng gói XOR	Tấn công chuỗi cung ứng vào nhiều host/tenant	SBOM, review, ký image, gate và rollback
RR08 DDoS hoặc lỗi thiết bị mạng/ISP	Mất truy cập dịch vụ công khai, suy giảm khả dụng	Hai ISP, chống DDoS, FW/LB HA
RR09 SOC thiếu nguồn log hoặc mất dấu vết	Không phát hiện hoặc điều tra được sự cố	Ma trận nguồn, retention, chống sửa/xóa
RR10 Sự cố khu vực ảnh hưởng cả DC và DR	Hai IDC cùng gián đoạn do điện/cáp/thiên tai hoặc nhà cung cấp	Phân tích miền lỗi chung, bản sao và kế hoạch thay thế

Điểm, căn cứ và rủi ro còn lại: [CẦN HOÀN THIỆN sổ rủi ro với tài sản, khả năng, tác động, người phụ trách, bằng chứng, thời hạn và quyết định chấp nhận]. Danh mục trên là đầu vào đánh giá, chưa phải báo cáo đánh giá đã hoàn thành.

4 PHÂN TÍCH TÁC ĐỘNG VÀ YÊU CẦU LIÊN TỤC

Đối với từng dịch vụ thiết yếu, cần lượng hóa số khách hàng và hệ thống bị ảnh hưởng, dữ liệu có thể mất/lộ/sửa, thời gian gián đoạn, hậu quả tài chính, pháp lý và tác động tới lợi ích công cộng, trật tự, an toàn xã hội hoặc an ninh quốc gia nếu có. Mọi kết luận về hậu quả phải kèm nguồn, giả định và người xác nhận. [S1, Điều 22.5 b c]

Dịch vụ	Phụ thuộc cần đối chiếu	Chỉ tiêu và căn cứ
DV01 IAM và quyền quản trị	IdP, Keystone, MFA, PAM	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV02 Khóa và chứng thư	KMS/HSM, PKI, bản sao khóa	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV03 Điều khiển cloud	API, DB trạng thái, queue, SDN controller	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV04 Máy ảo và container	Compute, network, image, storage	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV05 Dữ liệu và lưu trữ	Block, object, file, DB theo dịch vụ	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV06 DNS và thời gian	DNS nội bộ/công khai, NTP	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV07 SOC và nhật ký	Collector, SIEM, kho log	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV08 Sao lưu và DR	Repository, replication, runbook	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]
DV09 Phát hành XOR	Git, CI/CD, registry, signing	[CẦN ĐIỀN RPO, RTO, MTD; hợp đồng/BIA; người phê duyệt]

Nếu viện dẫn Điều 14 khoản 2, thuyết minh riêng yêu cầu vận hành 24/7 và việc không chấp nhận ngừng vận hành không có kế hoạch trước; xác định bên yêu cầu, loại gián đoạn, tác động và biện pháp đáp ứng. [S1, Điều 22.5 d]

Các chỉ tiêu RPO 15 phút/RTO 4 giờ từng nêu trong kiến trúc mẫu trước đây chỉ là ví dụ thiết kế, không được chuyển thành cam kết hoặc bằng chứng hiện trạng. Bản hồ sơ này để trống chỉ tiêu cho đến khi chủ dịch vụ và chủ quản phê duyệt.

PHẦN IV PHƯƠNG ÁN BẢO ĐẢM AN NINH MẠNG

1 Biện pháp quản lý và kỹ thuật

Phương án đối với từng yêu cầu TCVN được lập tại tài liệu 02, gồm mã đối chiếu, điều khoản/trang, yêu cầu diễn giải, phương án áp dụng tại XOR và bằng chứng cần có. Tài liệu 03 quy định trách nhiệm và các bước thực hiện. Trước trình ký, đơn vị vận hành bổ sung cấu hình thực tế, tài liệu ban hành và kết quả kiểm tra vào các vị trí quy định. [S1, Điều 22.6]

Nhóm	Phương án tổ chức thực hiện
Quản trị rủi ro và tài sản	Lập CMDB, phân loại dữ liệu, BIA, quản lý thay đổi và sổ rủi ro; cập nhật theo tần suất từng điều khoản.
Định danh và đặc quyền	Tài khoản cá nhân, quyền tối thiểu, MFA, PAM, tách vận hành/bảo mật/kiểm toán, thu hồi theo vòng đời.
Mạng và nền tảng	Phân vùng, microsegmentation, HA, FW/IPS/WAF/DDoS/DBF/NAC hoặc giải pháp tương đương có kiểm chứng; bảo vệ API và tenant.
Dữ liệu và khôi phục	Mã hóa, khóa, toàn vẹn, DLP, chữ ký số khi áp dụng; sao lưu độc lập; kiểm thử restore và DR.
Giám sát và ứng phó	SOC 24/7, log tối thiểu 6 tháng, đồng bộ thời gian, kho tách mạng, EDR, cảnh báo và playbook.
Phát triển và đánh giá	SSDLC cho bản fork XOR; SBOM, kiểm tra mã nguồn/dependency, kiểm thử trước phát hành, pentest trong/ngoài, retest.

2 Điều kiện đối với giải pháp tương đương

Trường hợp tiêu chuẩn cho phép phương án tương đương, hồ sơ phải xác định yêu cầu gốc, rủi ro, kiến trúc kiểm soát, khả năng bảo vệ đạt được, giới hạn, kết quả thử và người chấp thuận. Không dùng một câu cam kết chung hoặc chỉ tên sản phẩm để thay thuyết minh và bằng chứng.

3 BẢO ĐẢM AN TOÀN VẬT LÝ VÀ TRÁCH NHIỆM THUÊ NGOÀI

Các yêu cầu A.4 được kiểm tra riêng tại DC Cầu Giấy và DR Nam Thăng Long. Chủ quản yêu cầu IDC cung cấp bằng chứng phù hợp phạm vi phòng/rack XOR, bao gồm vị trí, điện/UPS, PCCC, chống sét, chống nước, tĩnh điện, môi trường, bảo vệ điện từ, camera và kiểm soát ra vào. Chứng chỉ của IDC chỉ là một nguồn bằng chứng; cần xác minh phạm vi và hiệu lực, không thay kết quả kiểm tra từng yêu cầu.

Nội dung	XOR	IDC hoặc bên cung cấp
Rack thiết bị và tài sản	Quản lý thiết bị, người được phép, niêm phong/bàn giao và inventory.	Hạ tầng phòng máy, điều kiện vật lý và kiểm soát vào/ra theo hợp đồng.
Điện và môi trường	Đấu nối, giám sát tải, cảnh báo và phối hợp bảo trì.	Bằng chứng hai nguồn từ hai trạm khác nhau, UPS, điều hòa, chống cháy/nước/sét theo A.4.
Camera và ra vào	Phê duyệt người, rà soát log liên quan, xử lý bất thường.	Giám sát 24/7, lưu camera tối thiểu 6 tháng, cung cấp trích xuất theo thẩm quyền.
Sự cố	Chỉ huy phản ứng với hệ thống, thông tin khách hàng theo trách nhiệm.	Thông báo sự cố cơ sở, hỗ trợ điều tra/phục hồi theo SLA.
Kiểm tra định kỳ	Tổ chức kiểm tra, đối soát bằng chứng và theo dõi khắc phục.	Cung cấp hồ sơ, tham gia kiểm tra theo hợp đồng và phạm vi cho phép.

4 Ranh giới trách nhiệm với khách hàng

Phụ lục hợp đồng xác định bên quản lý OS, ứng dụng, DB, dữ liệu, khóa, tài khoản, sao lưu và log. Đối với IaaS, khách hàng thường quản lý OS khách và ứng dụng; với dịch vụ quản lý, phần XOR chịu trách nhiệm phải được mô tả cụ thể. Cấp độ được công bố chỉ gắn với phạm vi đã phê duyệt và không chuyển toàn bộ trách nhiệm của chủ quản khách hàng sang XOR.

PHẦN V KẾ HOẠCH HOÀN THIỆN VÀ TÀI LIỆU KÈM THEO

Giai đoạn	Kết quả phải có	Đầu mối và hạn
1 Xác minh đầu vào	Pháp nhân, thẩm quyền, phạm vi, tiêu chí Điều 14, dữ liệu và dịch vụ.	[CẦN ĐIỀN người và hạn]
2 Xác nhận hiện trạng	Bộ as-built, CMDB, phiên bản, IP và các phụ lục PL01–PL07.	[CẦN ĐIỀN]
3 Bổ sung kiểm soát	Theo từng thiếu sót trong TCVN/Cloud; phê duyệt thay đổi, triển khai và lưu bằng chứng.	[CẦN ĐIỀN]
4 Kiểm tra và retest	T01–T12; báo cáo độc lập, BIA/RPO/RTO đo được, đóng phát hiện.	[CẦN ĐIỀN]
5 Ý kiến và thẩm định	Ý kiến chuyên trách; công văn và bộ hồ sơ đúng phiên bản; giải trình khi yêu cầu.	[CẦN ĐIỀN]
6 Phê duyệt và duy trì	Quyết định chủ quản; thông báo đúng phạm vi; lịch vận hành, kiểm tra và cập nhật.	[CẦN ĐIỀN]

DANH MỤC KÈM THEO HỒ SƠ TRÌNH

HS01 Tổng quan HTTT: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS02 Thiết kế hệ thống đang vận hành: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS03 Căn cứ đề xuất cấp độ: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS04 Phương án bảo đảm an ninh mạng: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS05 Ý kiến chuyên môn của đơn vị chuyên trách: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS06 Công văn đề nghị thẩm định: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS07 Ý kiến thẩm định: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS08 Tờ trình phê duyệt: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

HS09 Quyết định phê duyệt cấp độ: [CẦN ĐIỀN tên tệp, phiên bản, số/ngày và số trang thực tế].

Ý kiến thẩm định HS07 phải do cơ quan có thẩm quyền phát hành; ý kiến chuyên môn HS05 phải do đơn vị chuyên trách thực hiện. Tài liệu này không tự tạo kết quả của các chủ thể đó. Báo cáo rà soát và bằng chứng kỹ thuật HS10–HS16 được quản lý cùng danh mục tài liệu kèm theo.

Nguồn tham chiếu

[S1] Nghị định 331/2026/NĐ-CP: Điều 14, 18, 20–24 và Phụ lục. Nguồn chính thức: https://vanban.chinhphu.vn/?docid=219243&pageid=27160

[S2] TCVN 14423:2026: Điều 6, trang 58–81; Phụ lục A.4, trang 109–111. Đã đối chiếu bản được cấp phép nội bộ. Diễn giải trong hồ sơ phục vụ áp dụng tại XOR; không đính kèm bản tiêu chuẩn có bản quyền.

PHỤ LỤC PL01 DANH MỤC DỊCH VỤ VÀ ỨNG DỤNG

Mã bản ghi: [CẦN ĐIỀN]. Ngày chốt hiện trạng: [CẦN ĐIỀN]. Lập một phiếu cho từng đối tượng; bổ sung số thứ tự khi có nhiều bản ghi.

Trường thông tin	Nội dung hiện trạng cần hoàn thiện
Mã dịch vụ; tên; chức năng	[CẦN ĐIỀN]
Đối tượng và phạm vi phục vụ	[Nhóm khách hàng; địa bàn; số tenant; nghiệp vụ]
Chủ dịch vụ; đơn vị quản lý	[Tên; chức năng; đầu mối]
Thành phần và vị trí triển khai	[DC/DR; asset ID; cụm; vùng mạng; endpoint]
Phần mềm và hệ điều hành	[Tên; phiên bản; bản dựng; giấy phép; EOL]
Dữ liệu và dịch vụ phụ thuộc	[Mã PL05; IAM/DNS/KMS/DB/queue/storage và bên ngoài]
Ranh giới trách nhiệm	[XOR/khách hàng/nhà cung cấp; dẫn hợp đồng]
Năng lực và nghĩa vụ dịch vụ	[Tải; dung lượng; SLA; lịch hoạt động; dẫn BIA]
Tài liệu xác nhận	[Hợp đồng; CMDB; thiết kế; biên bản; mã EV]

Người lập: [CẦN ĐIỀN]. Người kiểm tra: [CẦN ĐIỀN]. Văn bản xác nhận/phê duyệt: [CẦN ĐIỀN]. Tài liệu kèm theo: [mã, tên, phiên bản, số trang, nơi lưu].

PHỤ LỤC PL02 THIẾT BỊ VÀ CẤU HÌNH VẬT LÝ

Mã bản ghi: [CẦN ĐIỀN]. Ngày chốt hiện trạng: [CẦN ĐIỀN]. Lập một phiếu cho từng đối tượng; bổ sung số thứ tự khi có nhiều bản ghi.

Trường thông tin	Nội dung hiện trạng cần hoàn thiện
Mã tài sản; loại; vai trò	[CẦN ĐIỀN; không gộp nhiều thiết bị khác cấu hình]
Site và vị trí	[Cầu Giấy/Nam Thăng Long; phòng; rack; U; địa chỉ thực tế]
Nhà sản xuất; model; serial	[CẦN ĐIỀN]
Cấu hình và phiên bản	[CPU/RAM/disk/NIC; firmware; hypervisor/OS; license]
Kết nối vật lý	[Cổng; peer; fabric A/B; tốc độ; loại cáp; bản vẽ số]
Nguồn và miền lỗi	[PDU/UPS/nguồn A/B; rack; failure domain]
Bảo trì và vòng đời	[Đơn vị; hợp đồng; EOL/EOS; lịch bảo trì]
Trách nhiệm và hiện trạng	[Chủ sở hữu; người quản lý; hoạt động/dự phòng; ngày kiểm kê]
Hồ sơ hiện trạng	[Bản vẽ vật lý; số/ngày phê duyệt hoặc tài liệu tương đương; EV]

Người lập: [CẦN ĐIỀN]. Người kiểm tra: [CẦN ĐIỀN]. Văn bản xác nhận/phê duyệt: [CẦN ĐIỀN]. Tài liệu kèm theo: [mã, tên, phiên bản, số trang, nơi lưu].

PHỤ LỤC PL03 PHÂN VÙNG MẠNG VÀ ĐỊA CHỈ

Mã bản ghi: [CẦN ĐIỀN]. Ngày chốt hiện trạng: [CẦN ĐIỀN]. Lập một phiếu cho từng đối tượng; bổ sung số thứ tự khi có nhiều bản ghi.

Trường thông tin	Nội dung hiện trạng cần hoàn thiện
Mã mạng; chức năng; site	[CẦN ĐIỀN; vùng Z01–Z12 tương ứng]
Định danh phân đoạn	[VLAN; VRF; VXLAN/VNI; project; network ID]
Địa chỉ và điểm cuối	[CIDR; gateway; IP private/public; VIP; FQDN; asset ID]
Định tuyến	[Bảng route; next-hop; miền định tuyến; đích được phép]
Ranh giới và kiểm soát	[FW/SG/ACL/SDN; mã rule; chặn mặc định; chống giả mạo]
Quản trị và truy cập Internet	[Đường PAM; OOB; kiểm chứng mạng quản trị không kết nối Internet]
HA và phụ thuộc	[Peer; fabric; LB; DNS; NTP; khả năng failover]
Chủ mạng và thay đổi	[Đơn vị; đầu mối; ticket; ngày phê duyệt]
Hồ sơ hiện trạng	[Bản vẽ lô-gic; bảng IP; export route/rule đã xử lý bí mật; EV]

Người lập: [CẦN ĐIỀN]. Người kiểm tra: [CẦN ĐIỀN]. Văn bản xác nhận/phê duyệt: [CẦN ĐIỀN]. Tài liệu kèm theo: [mã, tên, phiên bản, số trang, nơi lưu].

PHỤ LỤC PL04 LUỒNG DỮ LIỆU VÀ KẾT NỐI HỆ THỐNG

Mã bản ghi: [CẦN ĐIỀN]. Ngày chốt hiện trạng: [CẦN ĐIỀN]. Lập một phiếu cho từng đối tượng; bổ sung số thứ tự khi có nhiều bản ghi.

Trường thông tin	Nội dung hiện trạng cần hoàn thiện
Mã luồng; mục đích	[CẦN ĐIỀN; căn cứ nghiệp vụ]
Hệ thống nguồn và đích	[Tên; chủ quản; cấp độ đã phê duyệt nếu có; bên chịu trách nhiệm]
Điểm kết nối	[Site; vùng; asset/IP/FQDN; cổng; giao thức; chiều khởi tạo]
Thông tin trao đổi	[Mã dữ liệu PL05; phân loại; dung lượng/tần suất]
Xác thực và quyền	[Danh tính kỹ thuật; phạm vi quyền; cơ chế xác thực; chu kỳ đổi khóa]
Mã hóa và kiểm tra toàn vẹn	[Giao thức; bộ mật mã; chứng thư; cơ chế bảo vệ theo phân loại]
Kiểm soát tại biên	[Rule/allowlist; WAF/IPS/gateway; kiểm soát tương đương nếu áp dụng]
Nhật ký và giám sát	[Trường log; đích collector; retention; cảnh báo; người quản lý]
Phê duyệt và kiểm thử	[Người duyệt; thời hạn; ticket; phép thử cho phép/từ chối; EV]

Người lập: [CẦN ĐIỀN]. Người kiểm tra: [CẦN ĐIỀN]. Văn bản xác nhận/phê duyệt: [CẦN ĐIỀN]. Tài liệu kèm theo: [mã, tên, phiên bản, số trang, nơi lưu].

PHỤ LỤC PL05 DỮ LIỆU VÀ QUYỀN TRUY CẬP

Mã bản ghi: [CẦN ĐIỀN]. Ngày chốt hiện trạng: [CẦN ĐIỀN]. Lập một phiếu cho từng đối tượng; bổ sung số thứ tự khi có nhiều bản ghi.

Trường thông tin	Nội dung hiện trạng cần hoàn thiện
Mã tập dữ liệu; mô tả	[CẦN ĐIỀN; nguồn và mục đích xử lý]
Chủ sở hữu và trách nhiệm	[Chủ dữ liệu; bên xử lý; XOR/khách hàng; căn cứ hợp đồng]
Phân loại và căn cứ	[Độ nhạy cảm; nghĩa vụ pháp lý/chuyên ngành; người phê duyệt]
Nơi lưu và bản sao	[Site; hệ thống; volume/bucket/DB; replica; backup; môi trường thử]
Ma trận quyền	[Nhóm/danh tính; đọc/ghi/xuất/xóa; phê duyệt; ngày rà soát]
Mã hóa và quản lý khóa	[Khi truyền/lưu; KMS/HSM nếu dùng; chủ khóa; khôi phục/thu hồi]
Lưu giữ và hủy	[Thời hạn; căn cứ; phương pháp; bản sao; biên bản xác minh]
Theo dõi và phục hồi	[Audit/DLP/toàn vẹn; job backup; RPO/RTO; phép thử]
Bằng chứng	[Danh mục; cấu hình che bí mật; log; ticket quyền; EV]

Người lập: [CẦN ĐIỀN]. Người kiểm tra: [CẦN ĐIỀN]. Văn bản xác nhận/phê duyệt: [CẦN ĐIỀN]. Tài liệu kèm theo: [mã, tên, phiên bản, số trang, nơi lưu].

PHỤ LỤC PL06 DỰ PHÒNG SAO LƯU VÀ KHÔI PHỤC THẢM HỌA

Mã bản ghi: [CẦN ĐIỀN]. Ngày chốt hiện trạng: [CẦN ĐIỀN]. Lập một phiếu cho từng đối tượng; bổ sung số thứ tự khi có nhiều bản ghi.

Trường thông tin	Nội dung hiện trạng cần hoàn thiện
Dịch vụ và mục tiêu được duyệt	[Mã PL01/BIA; RPO; RTO; MTD; người/ngày phê duyệt]
Phụ thuộc và thứ tự khôi phục	[Mạng/thời gian/DNS/IAM/KMS/storage/DB/queue/API/workload]
HA và quorum	[Cụm tại từng IDC; số thành viên; failure domain; ngưỡng chịu lỗi]
Sao lưu	[Dữ liệu/cấu hình/khóa; job; lịch; retention; mã hóa; kho độc lập]
Đồng bộ DC–DR	[Cơ chế; chiều; lịch; độ trễ đo; băng thông; kiểm tra nhất quán]
Năng lực DR và rủi ro chung	[Tải đáp ứng; nguồn điện; ISP/tuyến cáp; rủi ro đồng thời; biện pháp]
Kích hoạt và chuyển đổi	[Ngưỡng; người quyết định; fencing; runbook; truyền thông]
Chuyển về và khởi động nguội	[Điều kiện; đồng bộ ngược; rollback; bí mật khẩn cấp; phép thử]
Kết quả xác nhận	[Ngày; kịch bản; RPO/RTO đo được; đối soát; tồn tại; EV]

Người lập: [CẦN ĐIỀN]. Người kiểm tra: [CẦN ĐIỀN]. Văn bản xác nhận/phê duyệt: [CẦN ĐIỀN]. Tài liệu kèm theo: [mã, tên, phiên bản, số trang, nơi lưu].

PHỤ LỤC PL07 CẤU HÌNH VÀ PHIÊN BẢN NỀN TẢNG

Mã bản ghi: [CẦN ĐIỀN]. Ngày chốt hiện trạng: [CẦN ĐIỀN]. Lập một phiếu cho từng đối tượng; bổ sung số thứ tự khi có nhiều bản ghi.

Trường thông tin	Nội dung hiện trạng cần hoàn thiện
Thành phần và phạm vi	[Dịch vụ; site; asset/cụm; môi trường]
Nguồn và bản dựng	[OpenStack upstream; phiên bản XOR; commit/tag; digest]
Khác biệt và thành phần phụ thuộc	[Bản vá/tùy biến; SBOM; thư viện; giấy phép; hỗ trợ]
Baseline cấu hình	[Mã/phiên bản; hardening; IAM; log; giao thức; người duyệt]
Chuỗi phát hành	[Kho mã; pipeline; runner; registry; người review và duyệt]
Kiểm tra trước phát hành	[SAST/SCA/secret scan/DAST/pentest; phạm vi; kết quả; retest]
Triển khai và quay lui	[Ticket; ngày; cửa sổ; bản trước/sau; phương án rollback]
Theo dõi vận hành	[Drift; CVE; vá; EOL; tương thích và hiệu năng]
Bằng chứng và phê duyệt	[Release manifest; log triển khai; biên bản; người ký; EV]

Người lập: [CẦN ĐIỀN]. Người kiểm tra: [CẦN ĐIỀN]. Văn bản xác nhận/phê duyệt: [CẦN ĐIỀN]. Tài liệu kèm theo: [mã, tên, phiên bản, số trang, nơi lưu].